# ADR-0006 : Limitation des tentatives d'authentification (anti-force brute)

- **Statut :** Accepté — révisé le 2026-10-27
- **Date :** 2026-07-21 (décision initiale) ; 2026-10-27 (révision)
- **Décideurs :** Driss OUAAZIZ — Software Architect

## Historique des révisions

| DATE | RÉVISION |
|---|---|
| 2026-07-21 | Décision initiale : verrou de 5 échecs par IP et par nom d'utilisateur. |
| 2026-10-27 | Verrou à trois niveaux (IP, couple utilisateur/IP, compte à 50 échecs) pour supprimer le déni de service par verrouillage ciblé (constat F3) ; ajout de la limitation des mots de passe des liens publics (constat M4), constats de l'audit de sécurité d'octobre 2026 (document 14) ; question ouverte N1 (document 15). |

## Contexte et problème

Les points d'entrée d'authentification — connexion par mot de passe, vérification du code 2FA (TOTP) et vérification des codes de secours — sont exposés aux attaques par **force brute** et par **bourrage d'identifiants** (*credential stuffing*). Les liens publics protégés par mot de passe ( `/s/:token` ) et les pages de dépôt protégées ( `/r/:token` ) le sont également : leurs mots de passe sont souvent de courts codes, et chaque tentative coûte un calcul `bcrypt` non authentifié.

Deux exigences complémentaires s'imposent :

- **Freiner les tentatives répétées** sans pénaliser un utilisateur légitime.
- **Ne pas divulguer l'existence d'un compte** : la réponse à un identifiant inconnu ne doit se distinguer, ni par son contenu ni par son **temps de réponse**, de celle à un mot de passe erroné sur un compte existant.

Le mécanisme doit rester **robuste derrière comme sans reverse-proxy** : les en-têtes d'adresse client ( `X-Forwarded-For` , `X-Real-IP` ) sont trivialement falsifiables et ne peuvent être honorés que dans une topologie de confiance.

### Motif de la révision (octobre 2026)

La décision initiale verrouillait un **nom d'utilisateur** après 5 échecs, quelle que soit l'adresse d'origine. L'audit d'octobre 2026 a relevé que ce compromis, accepté à l'origine, permettait à **n'importe quel tiers de bloquer un compte connu** (un administrateur, par exemple) pendant 15 minutes avec cinq mauvais mots de passe, et de renouveler ce blocage indéfiniment (constat **F3**). Le même audit a relevé l'absence de toute limitation sur les mots de passe des liens publics (constat **M4**).

## Facteurs de décision

- Efficacité contre la force brute distribuée (rotation d'IP) et ciblée (compte).
- **Impossibilité pour un tiers de verrouiller à bas coût le compte d'autrui.**
- Non-divulgation de l'existence des comptes (contenu et timing).

- Robustesse face à la falsification d'adresse IP.
- Impact limité sur l'expérience des utilisateurs légitimes.

## Options envisagées

1. **CAPTCHA** — Ajoute une dépendance tierce et une friction utilisateur ; écarté à ce stade au profit d'un verrou côté serveur.
2. **Verrou par IP seule** — Contourné par la rotation d'adresses (attaque distribuée) et sensible à la falsification d'en-têtes.
3. **Verrou par compte seul** — Permet un déni de service ciblé (verrouiller un compte à volonté) et n'entrave pas le balayage multi-comptes.
4. **Verrou combiné IP + compte au même seuil (5)** — Décision initiale ; conserve le déni de service ciblé de l'option 3 (constat F3).
5. **Verrou progressif (délais croissants par compte)** — Atténue le déni de service sans le supprimer, et complexifie le raisonnement sur les délais.
6. **Verrou à trois niveaux : IP, couple (utilisateur, IP) au seuil normal, et compte toutes IP confondues à un seuil élevé, avec égalisation temporelle** *(retenu)*.

## Décision

### 1. Connexion par mot de passe

Trois limiteurs indépendants, en mémoire, partagent la même durée de verrou `LOCKOUT_SECS = 15 minutes` ( `backend/src/ratelimit.rs` ) :

| NIVEAU | CLÉ | SEUIL | REMISE À ZÉRO SUR SUCCÈS | RÔLE |
|---|---|---|---|---|
| **IP** | adresse cliente | `MAX_ATTEMPTS = 5` | Oui | Freine un client qui balaie plusieurs comptes |
| **Couple utilisateur / IP** | nom d'utilisateur + adresse | `MAX_ATTEMPTS = 5` | Oui | Arrête un client qui cible un compte, **sans bloquer ce compte pour les autres** |
| **Compte** | nom d'utilisateur, toutes IP | `ACCOUNT_MAX_ATTEMPTS = 50` | **Non** | Borne une attaque répartie sur de nombreuses adresses |

- La connexion est refusée (429) si l'un des verrous applicables est actif ; un échec est compté sur les trois clés à la fois.
- Le compteur **par compte n'est pas remis à zéro par une connexion réussie** : sinon un attaquant connaissant un autre compte, ou le titulaire légitime lui-même, réinitialiserait le budget d'une attaque distribuée. Il n'expire qu'avec le temps : à la fin du verrou, ou à la purge périodique (toutes les 30 minutes) une fois 15 minutes écoulées sans nouvel échec.
- Effet : pour verrouiller un compte, un tiers doit cumuler environ **50 échecs répartis sur au moins 10 adresses** (chaque adresse étant arrêtée à 5).
- La clé du couple (utilisateur, IP) est construite de façon non ambiguë ( `ratelimit::user_ip_key` ), afin qu'aucune paire ne puisse entrer en collision avec une autre.
- Un compte inconnu est compté et verrouillé de la même manière, afin que le limiteur ne serve pas d'oracle d'énumération.

### 2. Second facteur

- L'étape 2FA (jeton d'attente réutilisable pendant ses 5 minutes de validité) dispose d'un limiteur dédié, clé = nom d'utilisateur, seuil 5, protégeant la vérification TOTP **et** celle des codes de secours. Il n'est atteignable qu'après un mot de passe correct, ce qui exclut le verrouillage par un tiers.
- Ce même limiteur protège les opérations sensibles de gestion du second facteur (désactivation, régénération des codes de secours), qui exigent mot de passe **et** code.

### 3. Liens publics protégés par mot de passe (constat M4)

- Un limiteur dédié ( `link_limiter` ) compte chaque échec sur **deux clés** : `link:<jeton>` (borne une devinette répartie sur de nombreuses IP) et `ip:<adresse>` (borne un client qui balaie de nombreux liens).
- Au-delà de 5 échecs sur l'une des clés, la saisie est refusée pendant 15 minutes (réponse 429). Le contrôle intervient **avant** le calcul `bcrypt` .
- Un mot de passe correct n'efface que la clé du lien : un client ne peut pas remettre à zéro son compteur d'adresse avec un lien dont il connaît le mot de passe.
- Sur les pages de dépôt, le champ mot de passe doit précéder les fichiers dans le formulaire ; un fichier reçu avant validation du mot de passe est refusé, de sorte qu'un mauvais mot de passe ne coûte aucune écriture disque.

### 4. Dispositions communes (inchangées)

- La résolution de l'IP cliente **n'honore les en-têtes proxy que si `TRUST_PROXY_HEADERS` est activé** ; sinon, l'adresse du pair socket (non falsifiable) fait foi.
- **Égalisation temporelle** à la connexion : pour un identifiant inconnu, un calcul `bcrypt` factice est exécuté afin que le temps de réponse ne révèle pas l'existence du compte.
- Un verrou expiré est réinitialisé à la première sollicitation suivante ; un nettoyage périodique (toutes les 30 minutes) élague les entrées devenues sans effet, bornant l'empreinte mémoire.
- Les verrous vivent en mémoire et sont perdus au redémarrage du service.

## Conséquences

**Positives**

- Force brute ralentie sur les trois axes (adresse, couple, compte).
- **Un tiers ne peut plus verrouiller un compte avec quelques tentatives** : le titulaire légitime, depuis sa propre adresse, n'est bloqué que par le plafond global, coûteux à atteindre.
- Mots de passe des liens publics protégés contre la devinette et contre l'épuisement CPU par `bcrypt` .
- Absence de divulgation de l'existence des comptes (contenu et timing alignés).
- Résistance à la falsification d'IP hors topologie de confiance déclarée.
- Empreinte mémoire des limiteurs bornée par l'élagage.

**Négatives**

- Une attaque distribuée dispose d'un budget de 50 tentatives par compte et par fenêtre de 15 minutes (contre 5 auparavant) ; la robustesse des mots de passe et le second facteur restent déterminants.
- Un attaquant disposant d'au moins 10 adresses peut encore verrouiller un compte (déni de service plus coûteux, mais non supprimé).

- Le comptage par IP peut regrouper plusieurs utilisateurs légitimes derrière une même adresse (NAT) et les pénaliser conjointement.
- Les verrous étant en mémoire, un redémarrage les efface, et un déploiement multi-instance ne les partagerait pas.

**Risques résiduels**

- **Question ouverte N1** : la clé `link:<jeton>` permet à un tiers connaissant l'URL d'un lien protégé de le **bloquer pour tous** pendant 15 minutes, avec cinq mauvais mots de passe. Arbitrage en attente entre (a) conserver la clé par lien, qui protège les codes courts contre une devinette distribuée, et (b) un modèle analogue à la connexion (couple lien/IP au seuil normal et plafond par lien plus élevé). Suivi au plan directeur des scans (document 15).
- Une attaque **très largement distribuée** reste bornée par le plafond par compte ; **piste** : ajout ultérieur d'un défi (CAPTCHA) si la menace se matérialise.

## Références

- OWASP — *Authentication Cheat Sheet* (protection contre la force brute).
- Document 14 — rapport d'audit de sécurité d'octobre 2026 (constats F3, M4) ; document 15 — plan directeur des scans et rapports de sécurité (constat ouvert N1).
- Code : `backend/src/ratelimit.rs`, `backend/src/lib.rs` (`login`), `backend/src/{two_factor,shares,upload_requests,audit}.rs`.
- ADR-0002 (révocation JWT) — mesures d'authentification complémentaires.